

**TEMASEK POLYTECHNIC
SCHOOL OF INFORMATICS & IT
DIPLOMA IN CYBERSECURITY & DIGITAL FORENSICS**

**Case Study / Project / Case Presentation
AY 2022/2023 (October Semester Term B)**

IT SECURITY MANAGEMENT & AUDIT (CCD2C05)

INSTRUCTIONS TO CANDIDATES

1. This paper consists of **9** pages (including cover and content page)
2. This document describes the Case Study/Project and Case Presentation that you need to submit for **ITSMA**.
3. Please read it carefully, and follow through the submission instructions.
4. This case study / project comprises 40% of the subject while the case presentation comprises 25% of the subject

Content

1.	Purpose of the Case Study / Project	3
2.	Your task and deliverables	3
	i. Server Configuration Review (10 marks to individual).....	3
	ii. Audit Automation (10 marks to individual work).....	5
	iii. Report to CEO (10 marks to individual)	4
	iv. Group Research Report and Presentation (35 marks – 10 to group report, 10 to group presentation and 15 to individual presentation) – Self-Directed Learning.....	7
3.	Assessment scheme	8
4.	Late submissions	8
5.	Schedules	8
6.	Feedback and questions	9
7.	Teams.....	9
8.	Conduct	9

1. Purpose of the Case Study / Project

This Case Study / Project comprises of two parts and aims to provide learners with an opportunity to apply the technical audit skills which they have learnt from the practical sessions and also perform self-directed learning in researching on an important IT security management area.

The following are the specific skills that this Case Study / Project aims to hone in the learner:

- Recognising security vulnerabilities (or weaknesses) in the system
- Provide practical recommendation(s) to remediate the security vulnerabilities found
- Critical thinking of international security standards and regulations and implementation issues.

2. Your task and deliverables

i. Server Configuration Review (10 marks to individual)

On an individual basis, you will conduct a server configuration review (audit) of the following:

- 1 x CentOS Linux version 8 server (Case study / project VM)

The basic **inputs** to this task are

- Virtual Machines for the CentOS Linux version 8 (provided for download from one-drive)
- References - CIS benchmarks for CentOS Linux version 8 (in Politemall – References)

For the purpose of this exercise, you will only focus on the following sections in the CIS Benchmark:

Section 1.1 – Initial Setup
Section 2 – Services
Section 4.1.1 – Ensure auditing is enabled
Section 4.1.2 – Configure data retention
Section 4.1.3 – Configure auditd rule
Section 4.2.1 – Configure rsyslog
Section 4.2.3 – Ensure Permissions of Logfiles are configured
Section 4.3 – Ensure logrotate is configured
Section 5.1 – Configure time-based job schedulers
Section 5.2 – Configure SSH Server
Section 5.3 – Configure privilege escalation
Section 5.5 – Configure PAM
Section 5.6 – User Accounts and Environment
Section 6 – System Maintenance

The **output** of this task is

- Detailed issue sheets

The **format** of the detailed findings table is fixed. You can find it in the separate document in the Politemall called “Report to CEO (template) v2.docx” – Appendix A.

To pass: You identify configurations in the systems that does not comply to the CIS security standards. This activity is known by several different names, sometimes as a gap analysis or compliance review or compliance testing or security review.

You do not need to write scripts to perform the audit here. You can manually check the configurations without running scripts.

Please note that marks will be deducted if you report findings that are “false positives” – causing the audit team’s integrity to be questioned.

Number of vulnerabilities – The number of vulnerabilities is not available information. In real life, you would not know how many security gaps there are in a system. You need to find as many as you can.

Knowledge and skills: The lab sessions prepare you for this task. The method that you use to identify gaps can be manual as well as scripted e.g. you can examine a configuration file and identify the gaps by reading through the lines instead of writing a script.

ii. Report to CEO (10 marks to individual)

The **inputs** to this task are

- Outcome of the server configuration review conducted in sub-part i – “Server Configuration Review” above.
- Any other interesting observations you may have come across during the server configuration review.

The **content** of the report should include the following:

- Cover page
- (a) Executive summary (max 1 page)
- (b) Assessment on the current situation
- (c) Recommendations
- (d) Appendix A – Detailed issue sheets for CentOS Linux server from sub-part i - .
Server Configuration Review

Generally, an **(a) executive summary** should communicate the key messages in the shortest possible number of words. Someone who is “time poor” can quickly read it to find out what you want to say without looking into every detail. Based on your summary, he/she might be interested in finding specific details in the main body. This does not mean he/she will not read the body of the report.

The **(b) assessment on the current situation** should point out the broad/common issues across the different platform configuration which the group has reviewed. This view should be supported by facts gathered from the detailed issues sheets. With the available information, you might conclude with certainty or confidence that the company has a large gap in an area

e.g. patch management. As the details are already included in the Appendices, you should be only highlighting common problem areas and not going into specifics.

Based on your view of the current situation (b), you can then make **(c) recommendations** to address these higher level issues.

Again the recommendations should be broad and with reference to the detailed issue sheets.

You are also to prioritise the recommendations so that those which are of higher priority can be highlighted.

There is a suggested **format** for the project report. You can find it in the separate document in the Politemall called “ITSMA - Report to CEO (template) v2.docx”. You can use this format so that you spend less time on formatting. If you do use this format, you can still exercise a lot of flexibility in how you want to present your ideas.

Please note that although the content of the report is the most important component, the structure of report and how the report flow affects how well readers understand your thoughts.

iii. Audit Automation (10 marks to individual work)

You will write a script to automate the server configuration review on CentOS Linux 8 Servers.

The **inputs** to this task are

- Lab VM – DO NOT USE the case study / project VM you are auditing for this task because you might change the configuration
- Material from bash scripting lab

This is a separate activity from sub-part i and ii. You are advised to clone the “ITSMA – Project VM” or use your Lab VM for this sub-part. Please note that strictly speaking, your audit automation script must work by producing the correct audit outcome on any CentOS Linux Version 8 VMs.

The **output** of this task are

- Separate audit automation script file for each of the bullet points below

Your audit automation scripts will be tested and marked during the 2nd lab session of week 16 (week after flex week). Do come prepared with the automation VM loaded with your script files.

The script that you are assigned to will be based on your class register number:

Class Register number	Audit automation script assigned to you is
1,6,11,16,21 or 26	• 1.1.2 Ensure /tmp is configured • 4.1.11 Ensure events that modify user/group information are collected • 4.2.1.3 Ensure rsyslog default file permissions are configured • 5.5.5 Ensure default user mask is 027 or more restrictive • 6.2.8 Ensure users own their home directories

Class Register number	Audit automation script assigned to you is
2,7,12,17 or 22	• 1.1.6 Ensure separate partition exists for /var • 4.1.15 Ensure kernel module loading and unloading is collected • 5.2.7 Ensure SSH MaxAuthTries is set to 4 or less • 5.4.2 Ensure password expiration is 365 days or less for all users on the system • 6.2.16 Ensure no duplicate GIDs exist
3,8,13,18 or 23	• 1.1.11 Ensure separate partition exists for /var/log • 2.2.10 Ensure FTP Server is not enabled • 5.1.2 Ensure permissions on /etc/crontab are configured • 5.2.11 Ensure SSH PermitEmptyPasswords is disabled • 6.2.17 Ensure no duplicate user names exist
4,9,14,19 or 24	• 1.1.21 Ensure sticky bit is set on all world-writable directories • 1.1.22 Disable Automounting • 1.3.1 Ensure sudo is installed • 5.2.15 Ensure SSH warning banner is configured • 6.2.20 Ensure all users' home directories exist
5,10,15,20 or 25	• 1.3.3 Ensure sudo log file exists • 1.5.1 Ensure permissions on bootloader configuration files are configured • 1.5.2 Ensure bootloader password is set • 5.5.1.4 Ensure inactive password lock is 30 days or less • 6.2.6 Ensure root is the only UID 0 account

Each automation script shall provide 3 pieces of information:

- What is the script auditing? – **Audit title**
- Is there a non-compliance? Yes/No - **Non-compliance**
- What is not compliant? - **Details**

```
# .\itsma-p01-01.sh
```

```
Audit title: There is only one root id
```

```
Non-Compliance?: Yes
```

```
Details: See below
```

```
root:!0:0:0:/:usr/bin/bash
```

```
jdoe:*:0:1:John Doe:/home/jdoe:/usr/bin/bash
```

Figure 1: Example of script output

Tools – You should use bash to create your script.

Your script should cater for positive and negative cases. Simply put, it should say that there is a non-compliance when there is indeed one. It should keep silent when there is none.

Advice: You are advised not to spend time on fancy menus – no additional marks will be awarded. Priority is that the script works and provides accurate results.

Make sure you have backups of scripts. We will not entertain any request for dateline extensions due to any reason related to device failure.

Please refer to “ITSMA - Case Study & Project Audit Automation Testing guidelines.pdf” provided in Politemall for a sample of the testing requirements of audit automation items.

iv. Group Research Report and Presentation (35 marks – 10 to group report, 10 to group presentation and 15 to individual presentation) – Self-Directed Learning

You are to conduct a research into one the following information security related international standards and/or regulations:

- Computer Misuse Act
- Payment Card Industry – Data Security Standard
- Personal Data Protection Act
- Cybersecurity Act

The **output** of this task is

- Presentation slides (submitted to the learning management system prior to the presentation)
- Group research report (submitted to the learning management system after the presentation)

Your **research report** should include the following:

- (a) Background and introduction of the standards/regulations
- (b) History / Previous versions
- (c) Sections of the standards/regulations
- (d) Conclusion
- (e) References

Time – For the presentation, you are to prepare a deck of presentation slides to focus on the important research outcomes and divide the presentation time equally among the team members.

Attire – Smart Casual

Presentation skills – Some aspects of skilled presentations

- Clarity of presentation
- Ability to support your points with appropriate examples
- Ability to defend your points convincingly

Presentation slides – Some aspects of slides that strengthen the presentation

- Good presentation flow to bring key ideas across
- Simple and non-distracting slide layout that draws attention to what is required

- Use of good visual aids such as charts, diagrams etc that complements your presentation
- Avoid slides that only contain lengthy text paragraphs

3. Assessment scheme

	Individual	Group	Totals
<u>Case Study / Project</u>			
Server Configuration Review	10%	-	10%
Audit Automation	10%	-	10%
Report to CEO	10%	-	10%
Group Research Report	-	10%	10%
Sub-total	30%	10%	40%
<u>Case presentation</u>			
Presentation	15%	10	25%
Sub-total	15%	10	25%
Total	45%	20%	65%

4. Late submissions

Late submissions will attract penalties:

- Late and < 1 day – 10% deduction from absolute marks given for the part of the work e.g. if the assignment was worth 100 marks, you were given 75 marks for the work, after the penalty you are left with 65 marks i.e. $75 - 100 \times 10\%$
- Late ≥ 1 and < 2 days – 20% deduction from absolute marks
- Late ≥ 2 days – no marks will be awarded

5. Schedules

Quick summary of key dates:

- **2nd Practical Lab session in Week 16 (Week of 30 January 2022)** – Testing of all audit automation bash scripts.
- **By 22:00 of 4th February 2022 (Saturday)** – Please submit your presentation slides to the learning management system (Politemall).
- **By 22:00 of 25th February 2022 (Saturday)** – Please submit your group research report and individual Report to CEO to the learning management system (Politemall).

Please ensure that you keep all confirmation emails from Politemall as evidence of the date/time of your submissions.

6. Feedback and questions

You are encouraged to obtain feedback from your tutor and ask questions related to the requirements of the Case Study / Project & Case Presentation.

7. Teams

You will be working in **teams of up to 5** to complete group research report of the project.

The teams should be formed by Week 13.

8. Conduct

Be warned that students caught **plagiarising** will have serious consequences.